In the following subsection, we'll examine how ReBAC systems evaluate access at runtime and how policies use relationship paths to define rules.

6.1.1 How ReBAC works

Relationship-based access control (ReBAC) grants access based on the connections between entities, rather than just their identities or associated attributes. Instead of checking to see if a person holds a specific role or can claim certain attributes, ReBAC systems assess the relationship between the principal and the resource they want to access.

This is especially effective in systems where collaboration and delegation are key. You've already seen how ACME Corp's Customer Collaboration platform uses ReBAC to simplify access to documents, tickets, and deployment artifacts. Now let's take a closer look at how that system works.

Broadly speaking, a ReBAC system has three parts:

- *Static rules* define uniform access logic.
- The *authorization service* enforces those rules across all applications.
- The *relationship graph* provides data—connections between people, teams, and resources—that the system uses to decide whether to approve a request.

Importantly, the logic of a ReBAC system changes much less often than the rules change in other authorization models. Static authorization rules are written once and rarely updated. What does change are the relationships themselves: who owns a resource, who manages whom, and who has been granted viewer access. That makes ReBAC flexible without needing to change the underlying logic.

Figure 6.2 shows how ACME's platform evaluates access to documents in the Customer Collaboration system. When an employee tries to open a document, the authorization client sends a request to the central authorization service, which evaluates that request using rules and the current state of the relationship graph.